

Debre Berhan University

Department of Software Engineering

Fundamentals of Software Security (SEng7431) Lecture Note

Lec01: Introduction to Information Security

Zeynu M.(2016 E.C)

Outline

1 Chapter1:Basic Concepts of software security

- Introduction to software security
- Types of Security
- Threat,Vulnerability,Risk and Control
- Security issues(CIA) triad model
- Aspects of Information security

Introduction to software security

● What is Security?

- a property that a system or software behave
- protection or defense against **attack,interference,and espionage.**
- In general is about **protection** of of assets. This implies that in order to protect our assets, we must know the assets and their **values**.protection measures includes:
 - **Prevention** : to take measures to prevent the damage.
Example: locks on the door, guards, hidden places.
 - **Detection** : when, how and who of the the damage.
Example: thief alarm
 - **Reaction** :to take measures to recover from damage.
Example: calling the police.
- **Security** is a state of well-being of information and infrastructure.

- a protection of **assets** from harm or destroyed (property,infrastructure and information...etc.)



- Physical security (prevent burglary and theft of property)
- Societal security (security of critical infrastructures)
- National security (political stability and national integrity)
- Safety (security of life and health) and Environmental security
- Information security and data protection

● What is Safety and Security ?

- **Safety:** If the user supplies any input, then the system generates the desired output
 - Any input = Good output
 - Safe and protected from danger/harm
 - More features leads to a higher verification effort
- **Security:** If an attacker **supplies** unexpected input, then the system does not fail in specific ways
 - Bad input = Bad output
 - Protection of individuals, organizations, and properties against external threats
 - More features leads to a higher chance of attacks



- **What is Software Security ? :**

- involves people and practices, to **build** software systems, ensuring confidentiality, integrity and availability
- Related to the concepts
 - Cyber Security
 - Cryptography
 - Systems Governance
 - Software Engineering Concepts In Practice
- **Software Security** aims to **avoid** security vulnerabilities by **addressing** security from the early stages of software development life cycle.
 - Software security consists of building programs that continue to function correctly under malicious attack.
 - Software is one of the sources of security problems.

Why Software Security?

- Most software systems today contain numerous flaws and bugs that get exploited by attackers.
- New threats emerge everyday.
- Exponential increase in vulnerabilities in software systems.
- Programmers have a long history of repeating the same security-related mistakes!
- **challenge of software security**
 - Design flaws are likely.
 - Bugs seem inevitable. Therefore Flaws and bugs lead to vulnerabilities which are exploited by attackers.

Terminology

- **Defects** are implementation vulnerabilities and design vulnerabilities
- **Bugs** are implementation-level errors that can be detected and removed.
Example: Buffer overflow.
- **Flaws** are problems at a deeper level. They are instantiated in the code and present or absent at design-level.
Example: Error-handling problems
- **Failures** are the inability of the software to **perform** its required function.
- **Vulnerabilities** are errors that an attacker can exploit.
 - Either flaws in the design or flaws in the implementation.
 - Design-level vulnerabilities are the hardest defects to handle.
- **Risks** capture the probability that a flaw or a bug will impact the purpose of the software.

Risk = probability x impact

Types of Security

- **Computer security** :generic name for the collection of tools designed to protect data and to thwart hackers.
- **Network Security** :measures to protect data during their transmission
- **Internet Security** : measures to protect data during their transmission over a collection of interconnected networks.
- **Info Security** : is the protection of information and information systems from unauthorized **access, use, disclosure, disruption**, modification, or destruction concerned with the CIA of data.

- **Information:** is the most critical resource for many organizations so it must be protected.
- Due to the growth of networked data, security attacks have become a dominant problem in practically all information infrastructures.



- **Info Security**: the protection of information assets from damage or harm
- What are the **assets to be protected**?
Example: data files, software, IT equipment and infrastructure
- Information Security defined:
 - preservation of **confidentiality,integrity** and **availability** of information.
 - other properties such as **authenticity, accountability, non-repudiation** and **reliability**.

- **IS management** consists of activities to **control** and **reduce** risk of damage to information assets
- IS management focuses on:
 - **Evaluate** threats, vulnerabilities and risks
 - **Control** security risks by reducing vulnerability to threats
 - **Detection** and response to attacks
 - **Recovery** from damage caused by attacks
 - **Investigate** and **collect** evidence about incidents(forensics)

Threat, Vulnerability,Risk and Control

- **Threat Actor:** An active entity which can execute a threat scenario.
- **Threat Scenario:** The set of steps executed in a (potential) cyber attack.
- When simply using the term “threat”, it usually means a **threat scenario**.



- **Vulnerabilities**- Weaknesses or opportunities allowing a threat scenario to be executed
- **Security Risk**- Likelihood (ease of executing a threat scenario), combined with the potential damage in case of an incident (successful attack)
- **Security Control**- a method for removing vulnerabilities and reducing security risk

Security issues(CIA) triad model

- IS can consist of **three key** concepts :confidentiality, integrity, and availability.
- the three concepts are often called the **CIA triad** or sometimes called **security mechanisms, concepts, or properties**.
- In order to **prevent** and **detect** unauthorized actions by its users a **good security system** should provide (some of) the following features:
 - **Confidentiality** :is the prevention of unauthorized disclosure of information or keeping information private or safe due to this may also be known as **privacy or secrecy**.
 - **Integrity** :ability to prevent our data from being changed in an unauthorized or undesirable manner. could mean the **unauthorized change**.
 - **Availability** : refers to the ability to access data/Information should be accessible and usable upon appropriate demand. **authorized user**.

- **Example:Denial of service attacks** are a common form of attack against computer systems where by authorized users are **denied** access to the computer system.
 - Such an attack can be occur by the attacker **flooding the system** with **requests** until it cannot keep up and crashes.
- Generally CIA can be summarized as below
 - **confidentiality** is the protection of transmitted data from passive attacks.
 - **Integrity** means that data cannot be **modified , altered or changed** without authorization.
 - **Availability** is defined information and resources are available to **authorized parties**.

- the other principles of security

- Non-repudiation** - Sender cannot **deny** his/her intentions in the transmission of the information at a later stage.
- Authentication** - Sender and receiver can **confirm** each.

Example1 :consider the figure below



- Data privacy**: adversary should not be able to **read** message **M**
- Data integrity**: adversary should not be able to **modify** message **M**
- Data authenticity**: message **M** really originated from Alice

Exercise

- **Classify each of the following as a violation of confidentiality, of integrity, of availability, or of some combination**
 - John copies Mary's homework
 - Gina forges Roger's signature on a deed.
 - Abebe registers the domain name "AddisonWesley.com" and refuses to let the publishing house buy or use that domain name.
 - Carol changes the amount of Angelo's check from 100 dollar to 1,000 dollar.
 - Jonah obtains Peter's credit card number and has the credit card company cancel the card and replace it with another card bearing a different account number.

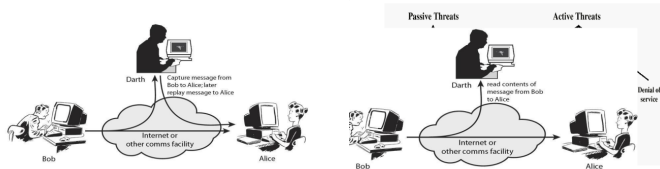
Aspects of Information security

● Threats and Vulnerabilities

- A **threat** is a potential **violation** of security.
- A threat is a set of circumstances that has the potential to **cause** loss or harm. The violation might occur, means that those actions that could cause it to occur must be guarded. Those actions are called **attacks**.
- Those who execute such actions, or cause them to be executed, are called **attackers**
- consider 3 aspects of information security:
 - Security Attack
 - Security Mechanism
 - Security Service

● Security Attack

- any action that compromises the security of information owned by an organization
- information security is about **how to prevent attacks**, or failing that to detect attacks on information-based systems
- often **threat** and **attack** used to mean same thing and focus of **generic types** of attacks:Passive and Active



- Categories of Attacks:

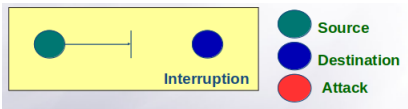
- **Interruption:** An attack on availability
- **Interception:** An attack on confidentiality
- **Modification:** An attack on integrity
- **Fabrication:** An attack on authenticity

① **Interruption:** An asset of the system is destroyed or becomes unavailable or unusable.

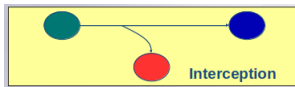
- This is an attack on availability

- **Examples:**

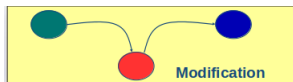
Destruction of hardware, cutting of a communication line



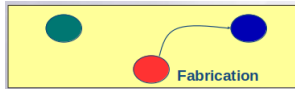
- 2 **Interception:** An unauthorized party gains access to an asset.
- Unauthorized party could be a person, a program or a computer.
 - **Examples:**Capture data in the network, Illegal copying of files.



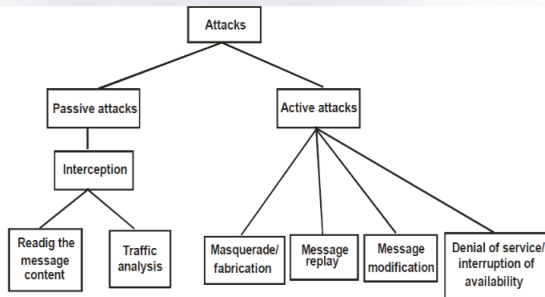
- 2 **Modification:** When an unauthorized party gains access and alters an asset.
- **Examples:**Changing data file, Altering a program and the contents of a message



- 4 **Fabrication:** -An unauthorized party inserts counterfeit objects into the system.
 - This is an attack on **authenticity**.
 - Example:** insertion of spurious message in a network or addition of records to a file.



- We have **two** types of Attacks



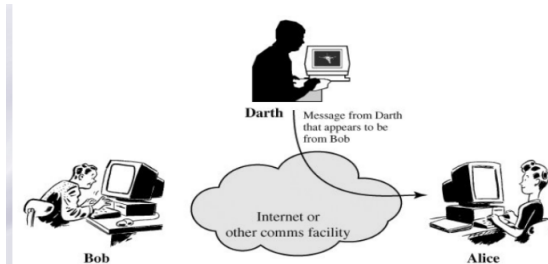
1

- **Active Attack**

- Active attacks involve some modification of the data stream or the creation of a false stream.
 - Masquerade,
 - Replay,
 - Modification of messages, and
 - Denial of service.

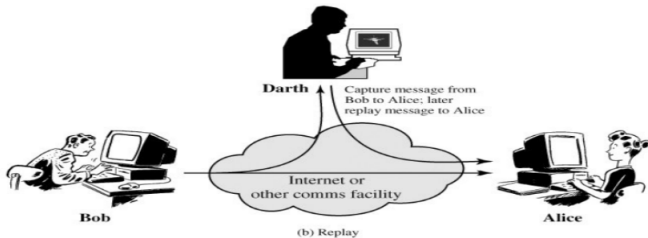
• Masquerade

- Here, an entity **pretends** to be some other entity.
- It usually includes one of the forms of active attack.



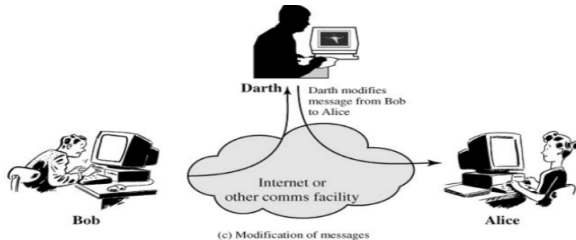
● Replay

- It involves **capture** of a data unit and its subsequent **retransmission** to produce an unauthorized effect.
- Can take place by sending the same message twice.



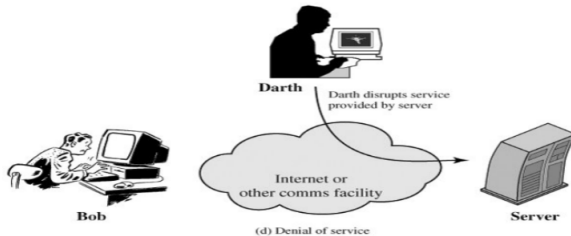
- **Modification of messages**

- It means that some portion of a legitimate message is **altered**, to produce an unauthorized effect.
- **Example:** "John's acc no is 2346" is modified as "John's acc no is 7892"



- **Denial of service**

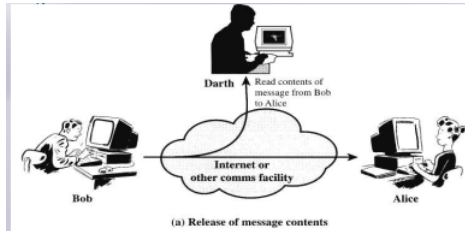
- This attack **prevents** the normal use of communication facilities.
- **Example:**a Disruption of entire network by disabling it.



- **Passive Attack**

- **Reading the message content**

- A Passive attack attempts **to learn** or make use of information from the system, but does **not** affect system resources.
- Passive attacks are very **difficult** to detect because they do not involve any alternation of the data.

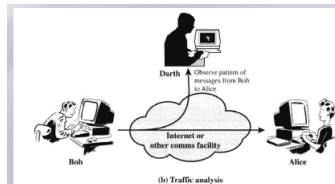


- Generally Active Attack

- It is quite **difficult** to prevent active attacks absolutely, because to do so would require physical protection of all communication facilities and paths at all times.
- Instead, the goal is to **detect** them and to **recover** from any disruption or delays caused by them. ²

● Traffic analysis

- It help passive attacker to observe the frequency and length of encrypted messages being exchanged there by guessing the nature of communication taking place.
- The number, size, frequency and times of messages sent, their sources and their destination can be leaked from these types of analysis.



3

- **Social engineering** : It is the psychological **manipulation** of people into performing actions confidential information.

Vulnerability

- **Vulnerability:** Weakness or fault that can lead to an exposure.
 - A particular system may be vulnerable to unauthorized data manipulation because the system does not verify a user's identity before allowing data access.
 - When we design, code, or test a secure system, we try to imagine the vulnerabilities that prevent us from reaching three security goals.
- **Software Vulnerabilities:** Software can be replaced, changed, or destroyed maliciously, or it can be modified, deleted, or misplaced accidentally.
 - Software Deletion
 - Software Modification
 - Software Theft

- In the Middle Ages, castles and fortresses were built to protect the people and valuable property inside.
- The fortress might have had one or more security characteristics, including
 - A strong gate or door, to repel invaders Heavy walls to withstand objects thrown or projected against them.
 - A draw bridge to limit access to authorized people Gate keepers to verify that only authorized people and
 - Computer security has the same characteristics. We have many controls at our disposal.
 - Some are easier than others to use or implement. Some are cheaper than others to use or implement.
 - And some are more difficult than others for intruders to override.

B.Security Mechanisms

- One of the most specific security mechanisms in use is cryptographic techniques.
- Encryption or encryption-like transformations of information are the most common means of providing security
 - **Encipherment** : It refers to the process of applying mathematical algorithms for converting data into a form that is not intelligible.
 - **Digital Signature** : The appended data or a cryptographic transformation applied to any data unit allowing to prove the source and integrity of the data unit and protect against forgery.
 - **Access Control** : A variety of techniques used for enforcing access permissions to the system resources.
 - **Data Integrity** : A variety of mechanisms used to assure the integrity of a data unit or stream of data units.
 - **Authentication Exchange** : ensuring the identity of an entity by means of information exchange.

Thank You !!!

